

RAPPORT DE VEILLE TECHNOLOGIQUE

Projet Infrastructure Cloud AWS | PixelStore

Jimmy Barbier, Dorian Poncelet, Matthieu Broquard

Jedha Bootcamp Cybersecurite Fullstack | Juin 2026

Résumé

Ce rapport examine deux technologies fondamentales appliquées dans le projet PixelStore : l'Infrastructure as Code avec Terraform, et la Défense en profondeur comme stratégie d'architecture de sécurité. Ces deux approches sont des standards reconnus de l'industrie qui ont guidé chaque décision de conception du projet. L'infrastructure déployée regroupe 77 ressources AWS organisées en 17 modules Terraform, provisionnées en une seule commande en 10 à 15 minutes.

1.

Infrastructure as Code (IaC) — Terraform

1.1 Vue d'ensemble

L'Infrastructure as Code est la pratique consistant à définir et gérer l'infrastructure informatique via des fichiers de configuration lisibles par machine, plutôt que par des processus manuels. Au lieu de cliquer dans une console cloud, les ingénieurs rédigent du code déclaratif qui décrit l'état cible de l'infrastructure.

Terraform, développé par HashiCorp et publié en 2014, est l'outil IaC open-source de référence. Il utilise son propre langage (HCL — HashiCorp Configuration Language) et un modèle basé sur des providers pour gérer des ressources sur plusieurs plateformes cloud : AWS, Azure, GCP.

1.2 Principes clés

Déclaratif	On décrit l'état cible ; Terraform calcule comment y parvenir.
Idempotent	Rejouer terraform apply produit le même résultat, sans duplicata ni dérive.
Gestion d'état	Terraform maintient un fichier d'état (.tfstate) reflétant les ressources réelles.
Modularité	Les ressources sont regroupées en modules réutilisables, avec séparation des responsabilités.
Plan avant Apply	La commande terraform plan prévisualise les changements avant toute application.

1.3 Application dans le projet PixelStore

L'intégralité de l'infrastructure AWS de PixelStore a été construite et gérée exclusivement via Terraform. Le projet est organisé en 17 modules indépendants :

- Réseau : VPC, subnets publics/privés Multi-AZ, Internet Gateway, NAT Gateway, tables de routage
- Sécurité : Security Groups en cascade ALB -> EC2 -> RDS, NACLs, WAF (3 règles gérées)
- Identité et secrets : Roles IAM moindre privilège, Secrets Manager pour credentials RDS et SECRET_KEY Flask
- Compute : Application Load Balancer, Auto Scaling Group, instances EC2 avec user_data automatisé

- Données : RDS MySQL Multi-AZ avec sauvegardes automatiques via AWS Backup (snapshot toutes les 12 h + binlogs/PITR)
- Observabilité : CloudWatch (4 alarmes + dashboard + SNS), CloudTrail multi-region, GuardDuty
- Stockage : Bucket S3 pour assets statiques et archive applicative

Une seule commande terraform apply provisionne les 77 ressources et livre un site e-commerce pleinement opérationnel en 10 à 15 minutes, sans intervention manuelle. L'état distant est stocké dans un bucket S3 chiffré avec verrou DynamoDB, permettant le travail en équipe.

1.4 Tendances et standards de l'industrie

L'IaC est devenu le standard de facto pour la gestion d'infrastructure cloud. Plusieurs tendances structurent son évolution :

- GitOps : stocker les configurations IaC dans Git permet le versionnement, la revue par les pairs et un historique d'audit complet.
- Policy as Code : des outils comme HashiCorp Sentinel ou Open Policy Agent (OPA) appliquent des règles de conformité directement dans le pipeline IaC.
- Détection de dérive : les workflows modernes incluent une détection automatique des écarts entre l'infrastructure réelle et l'état déclaré.
- IaC cloud-native : AWS CDK et Pulumi permettent de définir l'infrastructure dans des langages généraux (Python, TypeScript), élargissant l'adoption.

1.5 Référentiels et normes

Les pratiques IaC s'alignent sur plusieurs référentiels industriels :

- CIS Benchmarks : fournissent des bases de configuration durcies codifiables directement dans Terraform.
- SOC 2 / ISO 27001 : recommandent explicitement l'automatisation de l'infrastructure comme contrôle de gestion des changements.
- NIST SP 800-190 : recommande l'IaC pour les déploiements cloud afin de garantir des environnements reproductibles et auditable.

2.

Défense en profondeur — Architecture de sécurité multicouche

2.1 Vue d'ensemble

La Défense en profondeur (Defense in Depth) est une stratégie de sécurité qui emploie plusieurs couches indépendantes de contrôles. Le principe est issu de la stratégie militaire : si une ligne de défense est franchie, les couches suivantes continuent de protéger l'actif. En cybersécurité, aucun contrôle unique n'est considéré comme suffisant ; l'architecture est

deliberement concue pour qu'un attaquant doive surmonter plusieurs barrieres independantes pour atteindre sa cible.

Ce concept est formalise par le NIST (SP 800-53) et reference dans des referentiels tels qu'ISO/IEC 27001, les CIS Controls et le pilier Securite de l'AWS Well-Architected Framework.

2.2 Les sept couches de la defense en profondeur

Couche 1 — Politiques	Gouvernance, politiques d'usage acceptable, formation securite.
Couche 2 — Physique	Securite physique des datacenters (geree par AWS).
Couche 3 — Perimetre	Pare-feu, protection DDoS, WAF, filtrage frontalier.
Couche 4 — Reseau	VLANs, subnets, ACLs, VPNs, segmentation.
Couche 5 — Hote	Durcissement OS, gestion des correctifs, protection des endpoints.
Couche 6 — Application	Code securise, validation des entrees, controles d'authentification.
Couche 7 — Donnees	Chiffrement au repos et en transit, controles d'accès, sauvegardes.

2.3 Application dans le projet PixelStore

La Defense en profondeur a constitue la philosophie architecturale centrale guidant chaque decision de securite du projet PixelStore. Chaque couche est specifiquement adressée :

Couche perimetre — Cloudflare et WAF AWS

Le chiffrement TLS/HTTPS est assure par Cloudflare en frontal. Le WAF AWS deploye trois regles managed sur l'Application Load Balancer : AWS Managed Rules Common Rule Set (OWASP Top 10), protection SQLi, et limitation de debit anti-DDoS (blocage IP au-dela de 2 000 requetes par periode de 5 minutes). Le Security Group de l'ALB est restreint aux plages d'adresses IP de Cloudflare, empechant tout acces direct en HTTP. Au test, l'ensemble des payloads canoniques et quatre variantes d'evasion ont ete bloques avec un retour HTTP 403.

Couche reseau — VPC, Security Groups et NACLs

L'infrastructure repose sur une architecture trois tiers stricte : l'ALB en subnets publics, les instances EC2 en subnets publics dedies, la base RDS en subnets privs isolees. Les Security Groups appliquent un modele en cascade : seul l'ALB peut joindre EC2 sur le port 5000 ; seul EC2 peut joindre RDS sur le port 3306. Les NACLs constituent une seconde couche de filtrage stateless au niveau des subnets, avec ports ephemeres 1024-65535 explicitement configures.

Couche identite — IAM moindre privilege

Les instances EC2 disposent d'un role IAM avec les permissions minimales requises : lecture du bucket S3 (archive applicative) et GetSecretValue sur le secret Secrets Manager contenant les credentials RDS et la SECRET_KEY Flask. Aucune autre permission n'est accordee. L'acces administratif aux instances est realise exclusivement via AWS Systems Manager Session Manager, SSH etant completement desactive.

Couche secrets — AWS Secrets Manager

Les credentials RDS et la SECRET_KEY Flask (64 caracteres, generee par Terraform) sont stockes dans AWS Secrets Manager, jamais en clair dans le code ou les variables d'environnement. L'application les recupere via le SDK AWS au demarrage et refuse de demarrer en l'absence d'une cle forte.

Couche detection — GuardDuty, CloudTrail et CloudWatch

GuardDuty analyse en continu les VPC Flow Logs, les logs DNS et les evenements CloudTrail pour detecter les comportements anormaux. Les findings de severite moyenne et haute (≥ 4) declenchent une alerte via EventBridge vers un topic SNS. CloudTrail capture chaque appel API du compte (retention 90 jours). CloudWatch surveille quatre metriques cles avec alertes SNS : CPU EC2 $> 80\%$, erreurs 5xx ALB $> 10/\text{min}$, latence ALB $> 2\text{ s}$, connexions RDS > 50 .

Couche application — Durcissement applicatif

L'application est servie par Gunicorn (serveur WSGI de production), Werkzeug ayant ete retire. Les mots de passe sont haches avec bcrypt. Les requetes SQL sont toutes parametrees via PyMySQL, eliminant les injections SQL au niveau applicatif. Les en-tetes de securite HTTP sont appliques (CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy). Les cookies de session sont configures Secure + SameSite=Lax + HttpOnly. Une politique de mot de passe serveur impose 12 caracteres minimum avec complexite. L'application s'execute sous un utilisateur non privilegie et les redirections sont restreintes aux chemins internes (protection open redirect).

Couche donnees — RDS Multi-AZ et chiffrement

La base MySQL est deployee en configuration Multi-AZ avec une replique synchrone en eu-west-3b ; la bascule automatique s'effectue en 1 a 2 minutes. Les sauvegardes automatiques RDS et un plan AWS Backup (snapshots toutes les 12 h) avec binlogs/PITR assurent un RPO d'environ 15 minutes. Les donnees au repos sont chiffrees en AES256 sur S3 et RDS. La retention des snapshots est de 7 jours.

2.4 Tendances et standards

- Zero Trust Architecture : evolution de la Defense en profondeur assumant qu'aucune confiance implicite n'existe. NIST SP 800-207 fournit le cadre formel.
- CNAPP (Cloud-Native Application Protection Platform) : outillage unifie combinant protection des charges de travail, gestion de la posture et securite reseau.
- Shift-Left Security : integration des controles de securite en amont du pipeline (DevSecOps) par analyse statique du code IaC — Checkov et tfsec appliquent les principes de Defense en profondeur directement dans la base Terraform.

- MITRE ATT&CK; Framework : largement utilise pour cartographier les controles defensifs face aux tactiques adversariales connues et identifier les lacunes.

3.

Synergie entre IaC et Défense en profondeur

L'Infrastructure as Code et la Defense en profondeur sont naturellement complementaires. L'IaC fournit le mecanisme pour implementer et enforcer de facon fiable des controles de securite multicouches a l'echelle :

- Coherence : Les controles de securite definis dans Terraform sont appliques de facon identique a chaque deployment, eliminant les erreurs de configuration manuelle.
- Auditabilite : Chaque controle de securite (regles WAF, configurations Security Group, politiques IAM) est versionne dans Git, fournissant une trace complete des modifications.
- Reproductibilite : Un environnement detruit peut etre entierement reconstruit avec toutes ses couches de securite en moins de 15 minutes, essentiel pour la reprise apres sinistre.
- Enforcement des politiques : Des outils d'analyse statique (Checkov, tfsec) peuvent scanner la base Terraform dans des pipelines CI/CD, validant les configurations avant tout changement.

Dans le projet PixelStore, cette synergie se manifeste concretement : un seul terraform apply provisionne non seulement l'infrastructure mais enforce simultanement les sept couches de securite, du cloisonnement reseau a la gestion des secrets en passant par la detection des menaces.

Conclusion

L'Infrastructure as Code avec Terraform et la Defense en profondeur constituent deux piliers complementaires de l'ingenierie cloud securisee moderne. L'IaC garantit que l'infrastructure est reproductible, auditable et coherente ; la Defense en profondeur garantit qu'aucune defaillance unique ne peut compromettre l'ensemble du systeme. Ensemble, ils representent le standard actuel de l'industrie pour construire des environnements cloud securises de niveau production.

Dans le contexte du projet PixelStore, les deux technologies ont ete appliquees de bout en bout : 17 modules Terraform gerant 77 ressources AWS, avec des controles de securite multicouches allant du cloisonnement reseau et de la protection WAF/Cloudflare a la gestion chiffree des secrets et a la detection continue des menaces.

Références

- HashiCorp — Terraform Documentation :
<https://developer.hashicorp.com/terraform/docs>
- NIST SP 800-53 Rev. 5 — Security and Privacy Controls for Information Systems
- NIST SP 800-207 — Zero Trust Architecture
- AWS Well-Architected Framework — Security Pillar
- CIS Controls v8 — Center for Internet Security
- MITRE ATT&CK; Framework — <https://attack.mitre.org>
- ISO/IEC 27001:2022 — Information Security Management Systems